

Jeremiah Grossman

Venture capitalist (Grossman Ventures <https://grossman.vc>), Internet protector and industry creator. Founded WhiteHat Security & Bit Discovery. BJJ Black Belt.

MONDAY, JANUARY 17, 2011

Top Ten Web Hacking Techniques of 2010 (Official)

Every year the Web security community produces a stunning amount of new hacking techniques published in various white papers, blog posts, magazine articles, mailing list emails, etc. Within the thousands of pages are the latest ways to attack websites, Web browsers, Web proxies, and so on. Beyond individual vulnerability instances with CVE numbers or system compromises, we're talking about actual new and creative methods of Web-based attack. Now it its fifth year the **Top Ten Web Hacking Techniques** list encourages information sharing, provides a centralized knowledge-base, and recognizes researchers who contribute excellent work.

Since inception of the Top Ten Web Hacking Techniques list, the diversity, volume, and innovation of security research has always been impressive. 2010 produced 69 new attack techniques! This years point-position [voting](#) system worked well and the results showed exceptionally strong competition throughout all the entries. In fact, only two entries did not gain any points.

I'd like to take a moment again to thank everyone who took the time to fill out the voting surveys including those who were on this years expert panel. [Ed Skoudis](#) (InGuardians Founder & Senior Security Consultant), [Giorgio Maone](#) (Author of NoScript), [Caleb Sima](#) (CEO, Armorize), [Chris Wysopal](#) (Veracode Co-Founder & CTO), [Jeff Williams](#) (OWASP Chairman & CEO, Aspect Security), [Charlie Miller](#) (Consultant, Independent Security Evaluators), [Dan Kaminsky](#) (Director of Pen-Testing, IOActive), [Steven Christey](#) (Mitre), and [Arian Evans](#) (VP of Operations, WhiteHat Security). Also a big thanks to our sponsors BlackHat, OWASP, [various Web security authors](#), and WhiteHat Security.



Today the polls are close, votes are in, and the official Top Ten Web Hacking Techniques of 2010 has been finalized! For any researcher simple the act of creating something unique enough to appear on the complete list is itself an achievement. To make it on to the top ten though, is well, another matter entirely. These researchers receive special praise amongst their peers who selected them and take their place amongst those highlighted in previous years (2006, 2007, 2008, 2009).

Top honors go to [Juliano Rizzo](#) and [Thai Duong](#) for their work on the "Padding Oracle" Crypto Attack" They'll receive a free pass to attend



BIO

Jeremiah Grossman brings 20+ years of experience in Computer Security and has become one of the most recognizable and world-renowned cybersecurity experts in the industry, coining several of the original hacking terms commonly used around the world today. Early in his career, Jeremiah was known as "The Hacker Yahoo" which led to his role as the company's Information Security Officer. Jeremiah founded WhiteHat Security (now Synopsis), and served as Chief of Security Strategy for SentinelOne which was the highest-valued cybersecurity IPO in history. Most recently, Jeremiah was the founder & CEO of Bit Discovery, which was acquired by Tenable in 2022. He also serves as a company advisor and board member to several tech startups. In his spare time, Jeremiah does Brazilian Jiu-Jitsu and is passionate about classic cars. He recently opened Toybox, a luxury car club in Boise, Idaho.

LINKS

[Jeremiah Grossman](#)

[Twitter](#)

[Facebook](#)

[LinkedIn](#)

[Grossman Ventures](#)

SUBSCRIBE

Posts

Comments



the BlackHat USA Briefings 2011! (sponsored by [Black Hat](#)) and a [library of autographed Web security books](#).



In second place is [Samy Kamkar](#) for his work on "Evercookie." He'll receive a free pass to OWASP Conference Pass (sponsored by OWASP).



And finally, everyone appearing on the top ten will receive custom designed t-shirt (sponsored by WhiteHat Security).

Top Ten Web Hacking Techniques of 2010!

1) 'Padding Oracle' Crypto Attack (poet, Padbuster, demo, ASP.NET)
Juliano Rizzo (@julianor), Thai Duong (@thaidn)

2) Evercookie
Samy Kamkar (@samykamkar)

3) Hacking Auto-Complete (Safari v1, Safari v2 TabHack, Firefox, Internet Explorer)
Jeremiah Grossman (@jeremiahg)

4) Attacking HTTPS with Cache Injection (Bad Memories)
Elie Bursztein (@ELIE), Baptiste Gourdin (@baptiste), Dan Boneh

5) Bypassing CSRF protections with ClickJacking and HTTP Parameter Pollution
Lavakumar Kuppan (@lavakumark)

6) Universal XSS in IE8 (CVE, White Paper)
Eduardo Vela (@sirdarckcat), David Lindsay (@thornmaker)

7) HTTP POST DoS
Wong Onn Chee, Tom Brennan (@brennantom)

8) JavaSnoop
Arshan Dabirsiaghi (@nahsra)

9) CSS History Hack In Firefox Without JavaScript for Intranet Portscanning
Robert "RSnake" Hansen (@rsnake)

10) Java Applet DNS Rebinding
Stefano Di Paola (@WisecWisec)

At [IT-Defense 2011](#) (Feb.) it will be my great honor to introduce each of the top ten during my "Top Ten Web Hacking Techniques of the

Year (2011)" presentations. Each technique will be described in technical detail for how they function, what they can do, to whom, and how best to defend against them. The audience will get an opportunity to better understand the newest Web-based attacks believed most likely to be used against us in the future.

The Complete List

1. Evercookie
2. Hacking Auto-Complete (Safari v1, Safari v2 TabHack, Firefox, Internet Explorer)
3. Cookie Eviction
4. Converting unimplementable Cookie-based XSS to a persistent attack
5. phpwn: Attack on PHP sessions and random numbers
6. NAT Pinning: Penetrating routers and firewalls from a web page (forcing router to port forward)
7. Mapping a web browser to GPS coordinates via router XSS + Google Location Services without prompting the user
8. XSHM Mark 2
9. MitM DNS Rebinding SSL/TLS Wildcards and XSS
10. Using Cookies For Selective DoS and State Detection
11. Quick Proxy Detection
12. Flash Camera and Mic Remember Function and XSS
13. Improving HTTPS Side Channel Attacks
14. Side Channel Attacks in SSL
15. Turning XSS into Clickjacking
16. Bypassing CSRF protections with ClickJacking and HTTP Parameter Pollution
17. CSS History Hack In Firefox Without JavaScript for Intranet Portscanning
18. Popup & Focus URL Hijacking
19. Hacking Facebook with HTML5
20. Stealing entire Auto-Complete data in Google Chrome
21. Chrome and Safari users open to stealth HTML5 AppCache attack
22. DNS Rebinding on Java Applets
23. Strokejacking
24. The curse of inverse strokejacking
25. Re-visiting JAVA De-serialization: It can't get any simpler than this !!
26. Fooling B64_Encode(Payload) on WAFs and filters
27. MySQL Stacked Queries with SQL Injection...sort of
28. A Twitter DomXss, a wrong fix and something more
29. Get Internal Network Information with Java Applets
30. Java DSN Rebinding + Java Same IP Policy - The Internet Mayhem
31. Java Applet Same IP Host Access
32. ASP.NET 'Padding Oracle' Crypto Attack
33. Posting raw XML cross-domain
34. Generic cross-browser cross-domain theft
35. One vector to rule them all
36. HTTP POST DoS
37. Penetrating Intranets through Adobe Flex Applications
38. No Alnum JavaScript (cheat sheet, jjencode demo)
39. Attacking HTTPS with Cache Injection
40. Tapjacking: owning smartphone browsers
41. Breaking into a WPA network with a webpage

42. XSS-Track: How to quietly track a whole website through single XSS
43. Next Generation Clickjacking
44. XSSing client-side dynamic HTML includes by hiding HTML inside images and more
45. Stroke triggered XSS and StrokeJacking
46. Internal Port Scanning via Crystal Reports
47. Lost in Translation (ASP's HomoXSSuality)
48. Cross Site URL Hijacking by using Error Object in Mozilla Firefox
49. JavaSnoop
50. IIS5.1 Directory Authentication Bypass by using "\$I30:\$Index_Allocation"
51. Universal XSS in IE8
52. padding oracle web attack (poet, Padbuster, demo)
53. IIS6/ASP & file upload for fun and profit
54. Google Chrome HTTP AUTH Dialog Spoofing through Realm Manipulation
55. NoScript Bypass - "Reflective XSS" through Union SQL Poisoning Trick
56. Persistent Cross Interface Attacks
57. Port Scanning with HTML5 and JS-Recon
58. Performing DDoS attacks with HTML5 Cross Origin Requests & WebWorkers
59. Cracking hashes in the JavaScript cloud with Ravan
60. Will it Blend?
61. Stored XSS Vulnerability @ Amazon
62. Poisoning proxy caches using Java/Flash/Web Sockets
63. How to Conceal XSS Injection in HTML5
64. Expanding the Attack Surface
65. Chronofeit Phishing
66. Non-Obvious (Crypto) Bugs by Example
67. SQLi filter evasion cheat sheet (MySQL)
68. Tabnabbing: A New Type of Phishing Attack
69. UI Redressing: Attacks and Countermeasures Revisited

Posted by [Jeremiah Grossman](#) at [10:05 AM](#)

14 comments:

soroush said...

Congrats. Cheers :)

January 18, 2011 at 7:50 AM

Anonymous said...

fantastic work !!!!

January 18, 2011 at 6:58 PM

Anonymous said...

I just Googled *Jeremiah* and your site was the first non-sponsored link.

January 19, 2011 at 9:37 AM

Jeremiah Grossman said...



@Anonymous: Nice! What country are you in? I'd like to double check it.

January 19, 2011 at 10:03 AM

kool said...

nice one...

January 20, 2011 at 1:02 AM

William J. Kelleher, Ph.D. said...



Hi Jeremiah!

Check out my essays on security. It's a different perspective.

Titles:

"Internet Voting: The Great Security Scare." Also, "The Reasonable Person Standard and the Critique of Leading Figures in the Making of Public Policy: The Case of Internet Voting." Finally, "Scary Stories Fail to Stop Internet Voting" updates the story. They are at, <http://ssrn.com/author=1053589>

Please let me know what you think of my POV.

William J. Kelleher, Ph.D.

Internetvoting@gmail.com

January 23, 2011 at 11:49 AM

Sro said...

Jeremiah, how can i send you short private message (a mail address or chat)?

January 26, 2011 at 12:50 AM

Jeremiah Grossman said...



@Sro: my first name @ whitehatsec.com

January 26, 2011 at 8:03 AM

Tom Brennan said...



hey where's my t-shirt ;)

January 31, 2011 at 7:55 AM

Jeremiah Grossman said...



@Tom: LOL, we should have them done by RSA. Are you going to be in attendance?

January 31, 2011 at 8:38 AM

Soroush said...

Jeremiah, I think it is betetr to have a link for submission of 2011 from now; and whenever we find something by creating/finding the new techniques, we can add it to the list. It will increase chance of having all the materials. Moreover I think, it encourages the people to participate and create the new techniques or publish them for free!

February 21, 2011 at 1:43 AM

Jeremiah Grossman said...



@Soroush: Great idea. I'll do exactly that!

February 21, 2011 at 10:31 AM

SanT said...



gOOd jOb....

March 19, 2011 at 10:09 AM

Anonymous said...

very hacking

August 14, 2011 at 3:20AM

[Post a Comment](#)

[Newer Post](#)

[Home](#)

[Older Post](#)

Subscribe to: [Post Comments \(Atom\)](#)

Picture Window theme. Powered by Blogger.

This site uses cookies from Google to deliver its services and to analyse traffic. Your IP address and user agent are shared with Google, together with performance and security metrics, to ensure quality of service, generate usage statistics and to detect and address abuse.

[LEARN MORE](#) [GOT IT](#)